Introduction to Computer Security – Computer-Based Exam

Gilles Grimaud

02/18/2026

General Context

We consider a simplified *Proof of Concept* (PoC) for managing names and credit card numbers. In this system:

- user names are stored in plaintext,
- credit card numbers are encrypted,
- the encryption key is only available after a startup phase involving two distinct authorities,
- the overall design is intentionally flawed and incomplete from a security standpoint.

The PoC is provided in the form of shell scripts and a data file. The detailed operation of the system, the data format, and the cryptographic choices are described in the `README.md` file, which is an integral part of the exam subject.

Important: this PoC is not an example of best practice. It is intended solely as a pedagogical support for studying vulnerabilities and security mechanisms.

Instructions

- All answers must be written in a file named `ANSWERS.md`.
- Answers must be justified, concisely but rigorously.
- When relevant, you may rely on the properties of the cryptographic algorithms used.

Part I – Understanding the PoC

This first part aims to verify your understanding of the overall functioning of the PoC.

Q1. Does the PoC demonstrate an intention to implement two-factor authentication?

Justify your answer based on the role of the different system components.

Q2. What encryption algorithm is used to protect the credit card numbers?

Q3. Without decrypting the data, is it possible to determine whether two users use the same credit card?

Justify your answer.

Part II – First Family of Attacks

In this part, we assume that the attacker has managed to obtain illegal access to the file serving as the database (the file containing the encrypted credit cards).

We assume, however, that the attacker does **not have access** to the master key, which is only present in memory (ramdisk).

Q4. How can the attacker modify the data file so that, during a later read operation, the decrypted credit card number has its first digit increased or decreased by 1 (for example `2111` becomes `3111`)?

Precisely justify the technique used.

Q5. Given that a credit card number consists of 16 digits, can any of these digits be modified using the same technique?

Justify your answer.

Q6. Can a 17^{th} digit be modified?

Justify your answer.

Part III – Second Attack: Payment Impersonation

We now consider a more realistic attack.

The attacker has a customer account with this merchant. They have managed to view and modify the credit card file. Although the PoC uses a simple file, we consider that in a real system, such an attack could result from direct access to a database (for example via an SQL injection).

Q7. How can the attacker pay their own bills using another customer's credit card?

Describe the attack scenario.

Q8. Which elements of the data model or the cryptographic scheme make this attack possible?

Q9. Once the security flaw has been identified, how can the system administrators determine the compromised accounts (victims and attackers)?

Part IV – Countermeasures and Scheme Improvement

Following your remarks, the system designer wishes to improve the solution.

Q10. The designer claims that, in any case, if the attacker manages to read the application code, for example the `add.sh` script, they will always be able to bypass the new protection scheme.

What do you think? Justify your answer.

Q11. To avoid the problem identified in Part III, the designer proposes that the name be "repeated" inside the ciphertext, just before the credit card number in plaintext. During decryption, the program would first verify that the indicated name matches the one stored in plaintext, and refuse the operation if it is not identical.

Why would the attacker still be able to appropriate a third party's credit card? Justify your answer and specify the conditions required for this attack.

Q12. To address the problem in Part II, the designer proposes adding a new field after the three existing ones. This field would contain the SHA-256 of the IV concatenated with the base64-encoded credit card number. Thus, they argue, it would no longer be possible to modify the IV without the system detecting the problem.

What do you think of this countermeasure? Justify your answer.